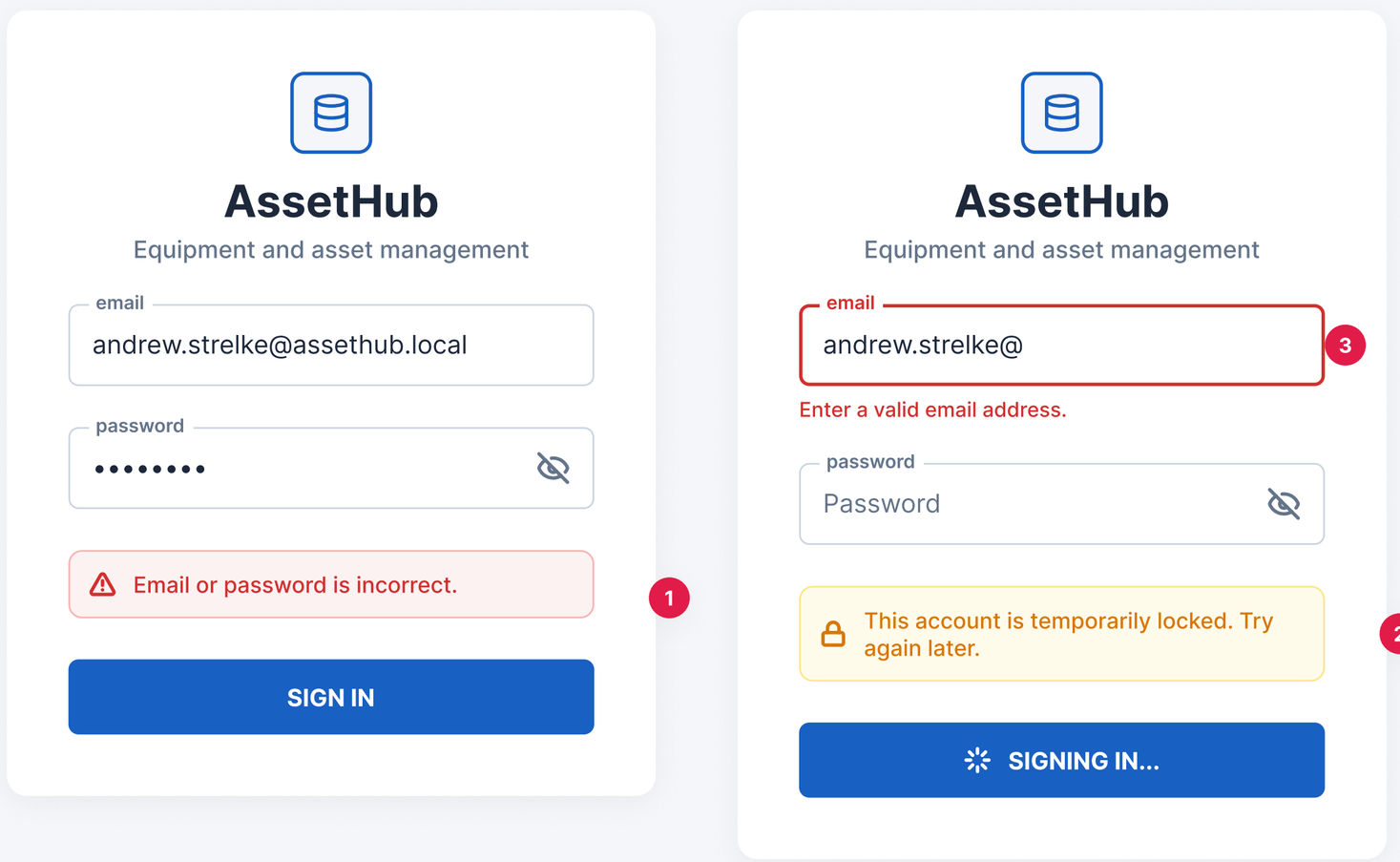
Sign in: failed-attempt, locked-account, and field validation



Authentication Error & Validation Rules

1. A wrong password, an unknown email and a deactivated account all show **exactly this message**. The screen must not reveal which one it was.
2. After 5 failed attempts the account locks for 15 minutes, and sign-in shows the locked message. The client recognises it by code: auth_account_locked, not by parsing the text, and shows it as a warning because trying again now will not help.
3. A malformed email is a validation failure shown under the field, not an authentication failure. The password field applies **no strength rules** at sign-in.

After signing in the user goes to returnUrl. If it is a relative path, otherwise to the dashboard. An absolute URL is ignored, so a crafted link cannot bounce a user to another site.